SIMATS ENGINEERING

CSA6303- Threat Intelligence and Network Security

A2-Vulnerability Assessment Report

Assessment Questions

Subject	Threat Intelligence	**Total Marks**	50
Questions	10 (all compulsory)	**Marks per Question**	5
REg.no		**Name of the Student**	

Co2: Identify common network attacks and analyze threat intelligence sources and data collection techniques.

Code of Conduct:

I G. Aswartha Manidheep(192425089) (Name / Reg No) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

G. Aswartha Manidheep

Signature of Student

A2-Vulnerability Assessment Report

Q1. Explain the common types of network attacks: malware, phishing, DoS and DDoS. Give one example and one preventive measure for each. (10 marks)
Key points: malware types (virus, worm, trojan, ransomware, spyware); phishing via deceptive emails, links or sites to steal credentials; DoS from a single source versus DDoS from a botnet; preventive measures such as antivirus, user awareness training, rate limiting, firewalls and CDN or traffic scrubbing.

Q2. What is a Man-in-the-Middle (MitM) attack? Describe how it works and the techniques used to carry it out, and list the countermeasures. (8 marks)
Key points: the attacker intercepts and may alter communication between two parties; techniques include ARP poisoning, rogue Wi-Fi access points, DNS spoofing and session hijacking; countermeasures include HTTPS/TLS, VPN, certificate validation, HSTS and dynamic ARP inspection.

Q3. Differentiate between spoofing and sniffing. Describe the types of spoofing and explain how sniffing can be detected or prevented. (8 marks)
Key points: spoofing is forging identity (IP, MAC, email or DNS spoofing); sniffing is passively capturing packets (Wireshark, tcpdump) and mainly exposes unencrypted data; prevention includes encryption, switched networks, port security and anti-spoofing filters.

Q4. Define vulnerability assessment. Explain its steps and describe the contents of a good vulnerability assessment report. (8 marks)
Key points: the process is asset identification, scanning (Nessus, OpenVAS), analysis, risk rating and reporting; the report contains an executive summary, scope and methodology, findings with CVE IDs, CVSS severity scores, evidence, risk impact and prioritized remediation recommendations; also mention how it differs from penetration testing.

Q5. What is Open-Source Intelligence (OSINT)? Discuss the common threat data sources and the techniques used to collect threat data. (8 marks)
Key points: OSINT draws on public sources such as WHOIS, Shodan, social media, news, forums, code repositories and the CVE/NVD databases; also cover commercial and internal sources (logs, honeypots) and collection techniques such as passive collection, web scraping and DNS or domain lookups; mention legal and ethical considerations.

Q6. What are Indicators of Compromise (IoCs)? Explain the types of IoCs and describe how threat feeds help organizations improve their defense. (8 marks)
Key points: IoCs are artifacts such as file hashes, malicious IPs, domains, URLs, registry keys and unusual network traffic; threat feeds (open-source or commercial, in formats like STIX/TAXII) deliver them for SIEM or firewall blocking and faster detection; limitations include false positives, stale data and the need for context.

ANSWERS

CSA6303 – Threat Intelligence and Network Security | A2 – Vulnerability Assessment Report

Q1. Common network attacks [10 Marks]

A network attack is an attempt to gain unauthorised access to, disrupt or steal data from a network or the systems on it. The four common types are explained below.

1. Malware

Malicious software designed to damage, spy on or take control of systems without the owner's consent. Main types: **virus** (attaches to files and spreads when they are run), **worm** (self-replicates across networks without user action), **trojan** (disguised as legitimate software, opens a backdoor), **ransomware** (encrypts files and demands payment) and **spyware** (secretly collects passwords and activity).

Example: WannaCry ransomware worm (2017) spread through the SMB vulnerability and encrypted data on hundreds of thousands of computers.

Preventive measure: up-to-date antivirus/EDR, regular patching and not running untrusted attachments or downloads.

2. Phishing

A social-engineering attack where the attacker sends deceptive emails, messages, links or fake websites that imitate a trusted organisation to trick users into revealing credentials, card details or installing malware. Variants include spear phishing, whaling, smishing and vishing.

Example: a fake "bank account blocked" email with a link to a cloned login page that captures the user's username and password.

Preventive measure: user awareness training, email filtering (SPF/DKIM/DMARC) and multi-factor authentication.

3. Denial of Service (DoS)

An attack from a **single source** that floods a server or network with traffic or malformed requests so that legitimate users cannot access the service.

Example: a SYN flood or ping flood from one machine that exhausts the server's connection table.

Preventive measure: firewalls, rate limiting and SYN cookies; block the offending source IP.

4. Distributed Denial of Service (DDoS)

A DoS attack launched from **many compromised machines (a botnet)** at once, producing very high traffic volumes that are hard to filter because they come from thousands of IP addresses.

Example: the Mirai botnet attack (2016) using hijacked IoT cameras and routers against the DNS provider Dyn.

Preventive measure: CDN and traffic-scrubbing services, load balancing, rate limiting and an ISP/cloud DDoS protection service.

Attack	Example	Preventive measure
Malware	WannaCry ransomware	Antivirus/EDR and patching
Phishing	Fake bank login email	User awareness training, MFA
DoS	SYN/ping flood	Firewall, rate limiting
DDoS	Mirai botnet	CDN / traffic scrubbing

Q2. Man-in-the-Middle (MitM) Attack [8 Marks]

Definition: A MitM attack is one in which an attacker secretly places himself between two communicating parties (for example a user and a website), intercepting and possibly altering the data while both sides believe they are communicating directly with each other.

How it works

- **Interception:** the attacker gets into the communication path (by redirecting or copying traffic).
- **Decryption/relaying:** he reads or captures the data (credentials, session cookies, messages), and may modify it.
- **Forwarding:** the traffic is passed on to the real destination so that the victim notices nothing.

```
Victim  <------->  ATTACKER  <------->  Server/Website
          (reads / modifies traffic)
```

Techniques

- **ARP poisoning:** forged ARP replies make victims map the gateway's IP to the attacker's MAC address, so LAN traffic flows through him.
- **Rogue Wi-Fi access point (evil twin):** a fake hotspot with a familiar name captures all traffic of users who connect.
- **DNS spoofing:** false DNS responses redirect users to a malicious site that looks genuine.
- **Session hijacking:** the attacker steals a valid session ID/cookie and takes over the logged-in session.
- **SSL stripping:** downgrades HTTPS connections to plain HTTP.

Countermeasures

- **HTTPS/TLS** to encrypt traffic and **certificate validation** to verify server identity.
- **HSTS** to force HTTPS and prevent SSL stripping.
- **VPN** on untrusted/public networks.
- **Dynamic ARP Inspection (DAI)**, port security and static ARP entries on switches.
- Avoid unknown public Wi-Fi, use DNSSEC and secure cookies.

Q3. Spoofing and Sniffing [8 Marks]

Basis	Spoofing	Sniffing
Meaning	Forging identity (address, name) to impersonate a trusted entity	Capturing and monitoring packets travelling on a network
Nature	Active – sends fake data	Passive – only listens
Purpose	Deceive systems, bypass access control, hide the attacker	Steal information such as passwords or analyse traffic
Tools	hping, Ettercap, Scapy	Wireshark, tcpdump
Detection	Via anomalies and mismatched addresses	Very hard, since it does not alter traffic

Types of spoofing

- **IP spoofing:** forging the source IP in packets (used in DoS/DDoS and to bypass IP-based filters).

- **MAC spoofing:** changing the MAC address to impersonate another device or bypass MAC filtering.
- **ARP spoofing:** sending false ARP replies to redirect LAN traffic (basis of MitM).
- **DNS spoofing:** corrupting DNS responses to send users to fake sites.
- **Email spoofing:** forging the sender address of an email (used in phishing).

Sniffing – detection

- Look for NICs running in **promiscuous mode** (tools such as ifconfig/ip link, or AntiSniff).
- Detect ARP anomalies/duplicate MAC addresses with ARP monitoring tools (e.g., arpwatch) and IDS.
- Unusual DNS or latency behaviour; ping tests to see whether a host responds to packets not meant for it.

Sniffing – prevention

- Use **encryption** (HTTPS, SSH, VPN, WPA3) so captured data is unreadable.
- Use **switched networks** (not hubs), VLANs and **port security**.
- Anti-spoofing filters (ingress/egress filtering, DHCP snooping, Dynamic ARP Inspection) and physical security of network ports.

Q4. Vulnerability Assessment [8 Marks]

Definition: Vulnerability assessment (VA) is the systematic process of identifying, classifying and prioritising security weaknesses in systems, networks and applications so that they can be fixed before attackers exploit them.

Steps

- **Asset identification:** list all hosts, devices, applications and services in scope.
- **Scanning:** run automated scanners such as Nessus or OpenVAS to detect missing patches, misconfigurations and weak settings.
- **Analysis:** verify findings, remove false positives and identify root causes.
- **Risk rating:** score and rank vulnerabilities (CVSS, asset criticality, exploitability).
- **Reporting:** document the findings and recommendations.
- **Remediation and re-scan:** patch or mitigate, then verify that the issues are closed.

Contents of a good vulnerability assessment report

Section	Content
Executive summary	Non-technical overview of overall risk, key findings and business impact
Scope and methodology	Systems/IP ranges tested, dates, tools used and approach
Findings	Each vulnerability with its CVE ID, description and affected asset
Severity scores	CVSS score and rating (Low/Medium/High/Critical)
Evidence	Screenshots, scan output or proof of detection
Risk impact	Possible consequences to confidentiality, integrity and availability
Remediation	Prioritised recommendations (patch, configure, upgrade) with timelines
Conclusion/appendix	Summary, re-test plan and references

Vulnerability assessment vs penetration testing

Basis	Vulnerability Assessment	Penetration Testing
Goal	Identify and list weaknesses	Exploit them to prove real impact
Method	Mostly automated, broad	Manual + automated, deep and targeted
Output	Prioritised list of vulnerabilities	Proof of compromise and attack paths

Q5. OSINT and Threat Data Sources [8 Marks]

OSINT (Open-Source Intelligence): intelligence obtained by collecting and analysing information from publicly available sources, used in threat intelligence to identify attacker infrastructure, exposed assets, leaked data and emerging threats.

Common threat data sources

Source	Examples
OSINT / public	WHOIS, Shodan, social media, news, forums, paste sites, code repositories (GitHub), CVE/NVD databases
Internal	Firewall, IDS/IPS, SIEM and DNS logs, endpoint telemetry, honeypots, past incident reports
External/community	CERT-In, ISACs, vendor advisories, industry sharing groups
Commercial	Paid feeds and reports (Recorded Future, CrowdStrike, Mandiant)

Collection techniques

- **Passive collection:** gathering data without interacting with the target (search engines, public records, Shodan).
- **Web scraping/crawling:** automated extraction from websites, forums and paste sites.
- **DNS and domain lookups:** WHOIS, passive DNS and certificate transparency logs to map infrastructure.
- **Honeypots/log analysis:** capturing attacker behaviour and internal telemetry.
- **Feed ingestion and social media monitoring** using APIs.

Legal and ethical considerations

- Collect only publicly available data; do not break into systems or bypass authentication.
- Respect privacy laws (e.g., GDPR, India's IT Act/DPDP Act), terms of service and copyright.
- Avoid misuse of personal data; verify sources to prevent acting on misinformation.

Q6. Indicators of Compromise (IoCs) and Threat Feeds [8 Marks]

IoCs are pieces of forensic evidence or artefacts that indicate a system or network has been compromised or is under attack, such as file hashes, malicious IP addresses, domains, URLs, registry keys and unusual network traffic.

Types of IoCs

Type	Examples
File-based	File hashes (MD5/SHA-256) of malware, suspicious file names/paths

Network-based	Malicious IPs, domains and URLs, C2 communication, unusual outbound traffic or odd ports
Host-based	Registry key changes, new/unknown user accounts, suspicious processes, unusual login times
Email-based	Sender address, subject lines and attachments used in phishing

How threat feeds improve defence

A threat feed is a continuously updated stream of threat data (malicious IPs, domains, hashes). Feeds may be open-source (AlienVault OTX, abuse.ch) or commercial, and are shared in standard formats such as **STIX** (data format) and **TAXII** (transport protocol).

- Feeds are loaded automatically into **SIEM, firewalls, IDS/IPS and EDR** to block known malicious IPs, domains and hashes.
- They give **faster detection** and earlier warning of new campaigns, reducing response time.
- They improve visibility beyond the organisation's own data and help prioritise threats relevant to the sector.

Limitations

- **False positives** can block legitimate traffic or flood analysts with alerts.
- **Stale data:** indicators such as IPs change quickly and become outdated.
- **Lack of context:** raw indicators need analysis and correlation to be actionable.